



Bundesamt
für Sicherheit in der
Informationstechnik

Deutschland
Digital•Sicher•BSI

Technische Richtlinie TR-03172-1 Portalverbund Teil 1: Onlinegateway

Version 1.0



Änderungshistorie

<i>Version</i>	<i>Datum</i>	<i>Name</i>	<i>Beschreibung</i>
1.0	22.10.2025	BSI, Referat D25	Veröffentlichungsfassung

Tabelle 1: Beschriftung

Bundesamt für Sicherheit in der Informationstechnik
Postfach 20 03 63
53133 Bonn
Tel.: +49 22899 9582-0
E-Mail: portalverbund@bsi.bund.de
Internet: <https://www.bsi.bund.de>
© Bundesamt für Sicherheit in der Informationstechnik 2025

Inhalt

1	Einleitung.....	4
1.1	Einordnung in den Portalverbund.....	4
1.2	Zielsetzung und Abgrenzung	5
2	Rahmenbedingungen.....	6
2.1	Modell- und Prozessbeschreibung.....	6
2.1.1	Sammlerdienst	6
2.1.2	Suchdienst und Bereitstelldienst.....	8
2.2	Schlüsselwörter	9
3	Sicherheitsanforderungen	10
3.1	Allgemeine Anforderungen	10
3.2	Architektur und Infrastruktur	10
3.3	Build-, Release- und Deploymentmanagement.....	11
3.4	Authentisierung, Authentifizierung und Autorisierung	12
3.5	Session-Management	12
3.6	Schnittstellen und Datenübertragung.....	13
3.7	Protokollierung und Detektion.....	14
3.8	Konfiguration	14
3.9	Fehlerbehandlung.....	15
	Literaturverzeichnis	16

1 Einleitung

1.1 Einordnung in den Portalverbund

Die BSI-TR-03172 Portalverbund umfasst ein Rahmendokument [1] mit übergreifenden Aspekten sowie Teildokumente zu den einzelnen Komponenten. Das Rahmendokument enthält ein zentrales Glossar mit allen verwendeten Begriffsbestimmungen sowie ein zentrales Abkürzungsverzeichnis, daher sind die Dokumente stets in Kombination zu lesen.

Die vorliegende *Technische Richtlinie TR-03172-1, Teil1: Onlinegateway* ist ein Teildokument zur Technischen Richtlinie BSI-TR-03172 Portalverbund [2]. Kernaufgaben des Onlinegateways sind die Bereitstellung eines Dienstverzeichnisses von allen angeschlossenen Portalen des Bundes, der Länder und der Kommunen sowie die Vermittlung der angebotenen Onlineleistungen an die Nutzenden des Portalverbundes durch Verlinkung auf die entsprechenden Webseiten der jeweiligen Onlinedienste.

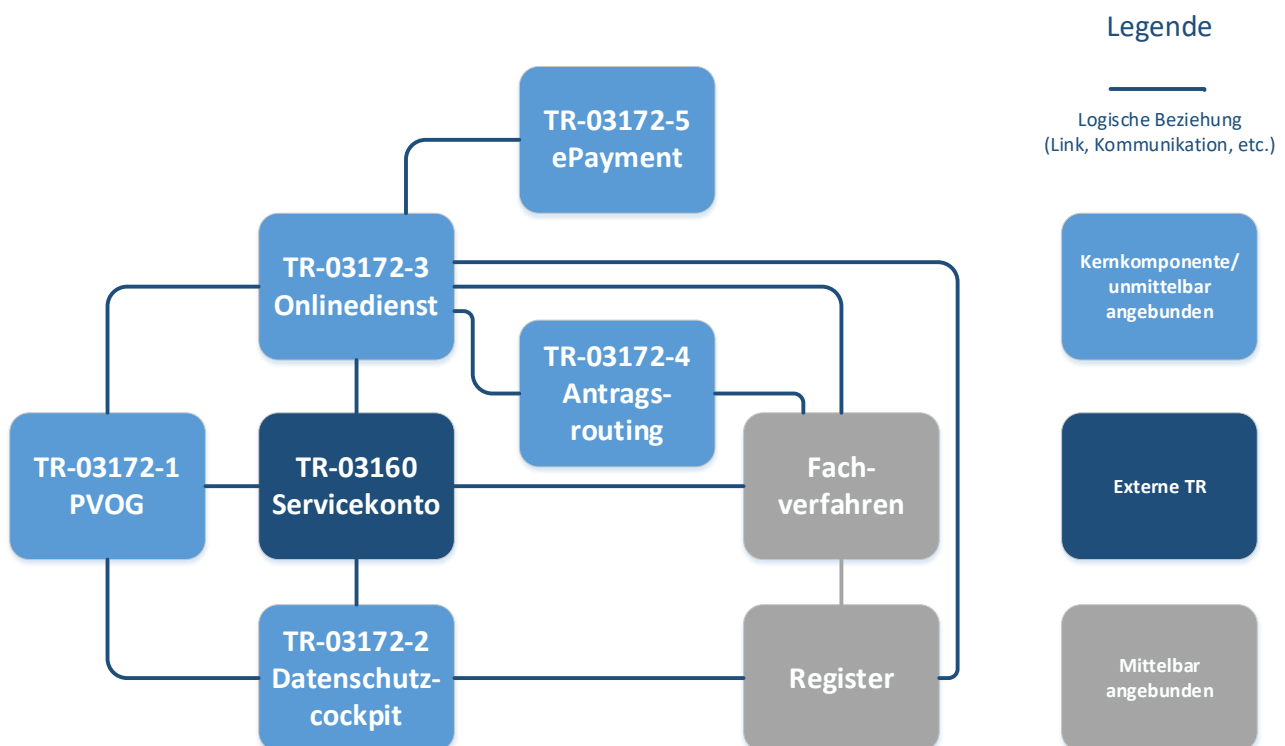


Abbildung 1: Einordnung in den Portalverbund

In Abbildung 1 sind die wichtigsten Komponenten des Portalverbundes zusammen mit ihren logischen Beziehungen dargestellt. Die exemplarische Darstellung soll an dieser Stelle keinen Anspruch auf Vollständigkeit erheben. Dem Onlinegateway als Sammelpunkt aller Leistungsbeschreibungen der Verwaltungsportale fällt dabei eine zentrale Rolle beim Informationsaustausch innerhalb des Verbunds zu. Hier werden alle Daten vorgehalten, um Bürgerinnen, Bürger und Unternehmen über Verwaltungsangelegenheiten zu beauskunften. Die wichtigsten Informationen umfassen die Verwaltungsleistungen nach dem Leistungskatalog (LeiKa), die Aufteilung in Gebietsstrukturen nach dem amtlichen Regionalschlüssel (ARS), die zuständigen Stellen (Organisationseinheiten), die Kontaktstellen sowie die damit verknüpften Onlinedienste. Von hier aus kann sich der Nutzende alle für ihn interessanten Verwaltungsleistungen gemäß den gewählten Suchkriterien auflisten und sich direkt mit dem verlinkten Verwaltungsportal oder Onlinedienst verbinden.

1.2 Zielsetzung und Abgrenzung

Die vorliegende Technische Richtlinie behandelt innerhalb des Portalverbundes die Komponente *Onlinegateway*. Zunächst werden im [Kapitel 2.1](#) die wichtigsten Prozesse in der Interaktion mit dem Onlinegateway aufgeführt und erläutert. Dies umfasst einerseits die Aktualisierung des internen Katalogs aller Verwaltungsleistungen über den Sammlerdienst (vgl. [Kapitel 2.1.1](#)) und andererseits die Weitergabe der konsolidierten Daten an die Nutzenden über den Such- bzw. Bereitstelldienst (vgl. [Kapitel 2.1.2](#)). Der Austausch der Leistungsbeschreibungen erfolgt hierbei im XML-basierten XZuFi Format [3]. Das Austauschformat selbst ist nicht Gegenstand der vorliegenden Technischen Richtlinie. Dem Sicherheitsanforderungsprofil des Sammler- und Bereitstelldienstes kommt eine gesonderte Betrachtung zu, da diese Dienste zwar über öffentliche Netze erreichbar, aber nur für einen eingeschränkten Nutzerkreis (den registrierten Konsumenten der Schnittstellen, z. B. den Redaktionssystemen) zugänglich ist. Der Suchdienst hingegen steht allen Nutzenden frei und anonym über einen Webdienst, den Suchclient, bzw. eine Schnittstelle (API) zur Verfügung.

Der sich anschließende Hauptteil der vorliegenden Technischen Richtlinie befasst sich in [Kapitel 3](#) mit der Formulierung von Sicherheitsanforderungen an das Onlinegateway. Hier sind systematisch alle Maßnahmen aufgelistet, die einen sicheren Betrieb im Hinblick auf die Informationssicherheit nach gegenwärtigem Stand der Technik gewährleisten sollen.

Die Anforderungen des vorliegenden Dokuments richten sich an die Entwickelnden und Betreiber des Onlinegateways. Neben dem sicheren Betrieb der Webanwendung liegt ein Schwerpunkt auf dem integritätsgeschützten Datenaustausch mit den Redaktionssystemen, die als Quellen der Verwaltungsbeschreibungen dienen, und der zuverlässigen Beauskunftung der Nutzenden des Suchdienstes. Hierbei behandeln die Anforderungen nicht nur den Webdienst, sondern vor allem die Hintergrundsysteme und Hintergrundprozesse sowie die (Fach-)administration und insbesondere die Schnittstellen zu externen Akteuren.

2 Rahmenbedingungen

2.1 Modell- und Prozessbeschreibung

Im Umfeld des Onlinegateway treten folgende Akteure in Erscheinung (vgl. Abbildung 2): anonyme Nutzer des Suchdienstes und seinem Suchclient, registrierte externe Konsumenten der Schnittstelle des Bereitstelldienstes, die Redaktionssysteme als Quellsysteme für die Beschreibungen der Verwaltungsleistungen und das Onlinegateway selbst in Funktion als IT- Komponente des Portalverbundes.

Um die Aufgaben, die an das Onlinegateway gestellt werden, abdecken zu können verfügt es über drei dedizierte Dienste: den Sammlerdienst, den Bereitstelldienst und den Suchdienst. Außerdem sind die Komponenten Administrationsdienst und Benutzerverwaltung für das funktionale Betreiben notwendig. Ein Überblick ist in Abbildung 2 dargestellt.



Abbildung 2: Akteure und Komponenten des Onlinegateways

Sammler-, Such- und Bereitstelldienst sind weiter unten in den Abschnitten 2.1.1 und 2.1.2 genauer beschrieben. Mit Hilfe des Administrationsdienstes werden die anderen Dienste konfiguriert. Zum Beispiel können neue Portale als Datenquelle an den Portalverbund angeschlossen, die Zeitpunkte der Datenabfragen über die Dienste- und Leistungsbeschreibungen konfiguriert oder für den Sammlerdienst Änderungen bei den angeschlossenen Redaktionssystemen vorgenommen werden. Die Benutzerverwaltung ermöglicht es den Nutzerkreis für den Bereitstelldienst auf registrierte Konsumenten der Schnittstelle einzuschränken um Datensätze des Dienstverzeichnis abzurufen. Dagegen können anonyme Nutzer nur einzelne Anfragen über den Suchdienst/ Suchclient stellen.

2.1.1 Sammlerdienst

Der Sammlerdienst ist für die Erfassung und Aktualisierung der Verwaltungsleistungsbeschreibungen, Organisationseinheiten (Ansprechpersonen) und Onlinedienste im Datenbestand des Onlinegateways verantwortlich. Dazu kommuniziert er mit den Redaktionssystemen der angeschlossenen Verwaltungsportale, die als Quellsysteme dienen. Hierzu sind zwei Verfahren etabliert: Beim Pull-Verfahren initiiert der Sammlerdienst den Datenaustausch mit dem Redaktionssystem als Quellsystem; über das Push-Verfahren können wichtige Änderungen vom Redaktionssystem aus jederzeit aktiv hochgeladen werden. Beide Prozesse sind in Abbildung 3 in Form eines Sequenzdiagramms dargestellt.

Beim Pull-Verfahren (links in Abbildung 3) ruft der Sammlerdienst alle Daten des Redaktionssystems ab. Hierzu müssen im Vorfeld Verbindungsparameter dem Sammlerdienst bekanntgemacht werden. Dazu wird das Redaktionssystem durch den Administrator des Onlinegateways im Sammlerdienst registriert und entsprechend konfiguriert. Der Sammlerdienst lädt anschließend alle Leistungsbeschreibungen herunter und prüft sie auf XML-Schemakonformität und Schadcode bevor die Daten übernommen werden.

Ähnlich verhält es sich beim Push-Verfahren, wie es auf der rechten Seite in Abbildung 3 dargestellt ist. Der Datenaustausch wird allerdings vom Redaktionssystem aus angestoßen. Es ist hier erforderlich, dass das

Redaktionssystem durch die Benutzerverwaltung des Onlinegateways authentifiziert wird. Anschließend wird die XML-Datei mit den Verwaltungsleistungen über die API-Schnittstelle des Sammlerdienstes hochgeladen. Es erfolgt analog zum Pull-Verfahren die Prüfung gegen das XML-Schema und auf Schadcode. Erst nach erfolgreicher Prüfung werden die Daten in den Katalog übernommen.

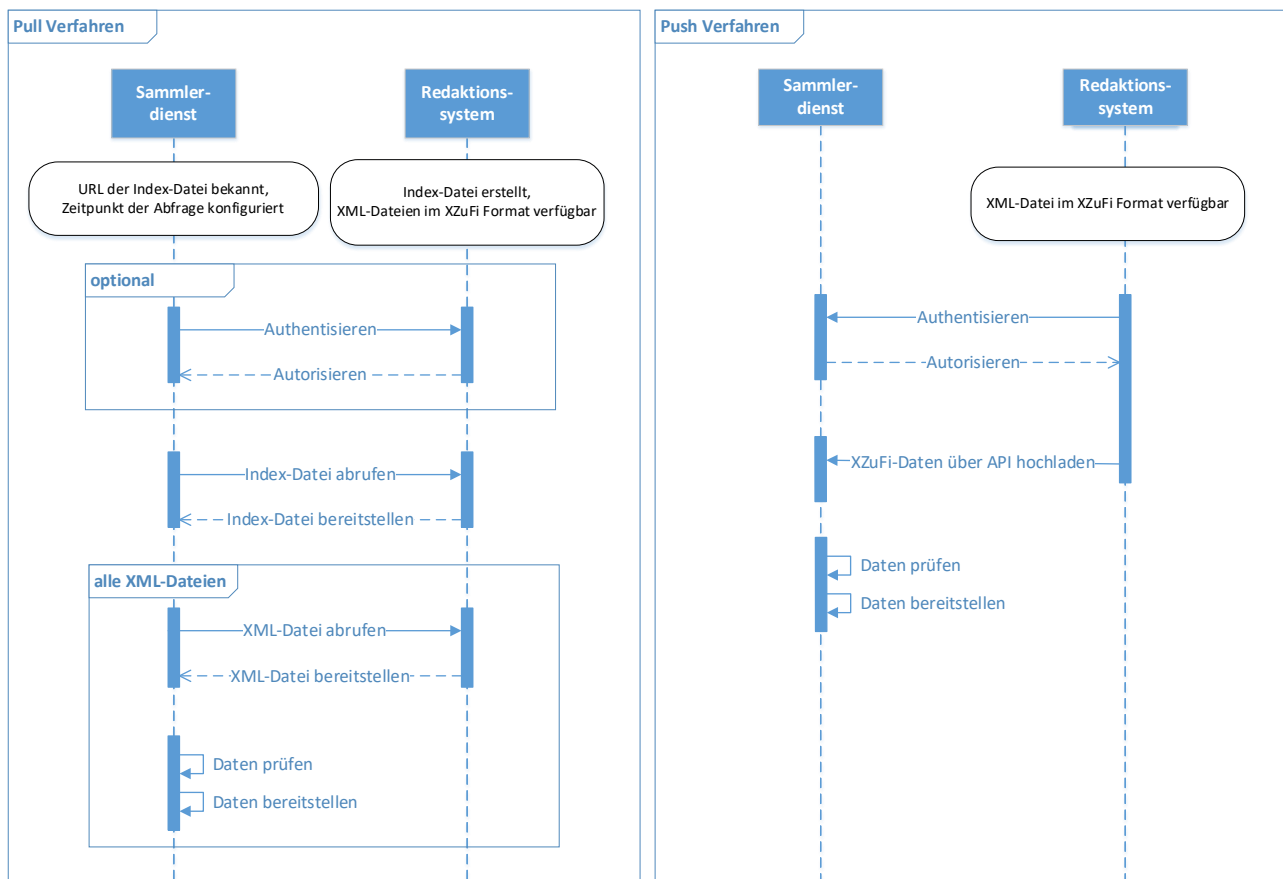


Abbildung 3: Push-Verfahren (links) und Pull-Verfahren (rechts) zum Datenaustausch zwischen Sammlerdienst und Redaktionssystem

2.1.2 Suchdienst und Bereitstelldienst

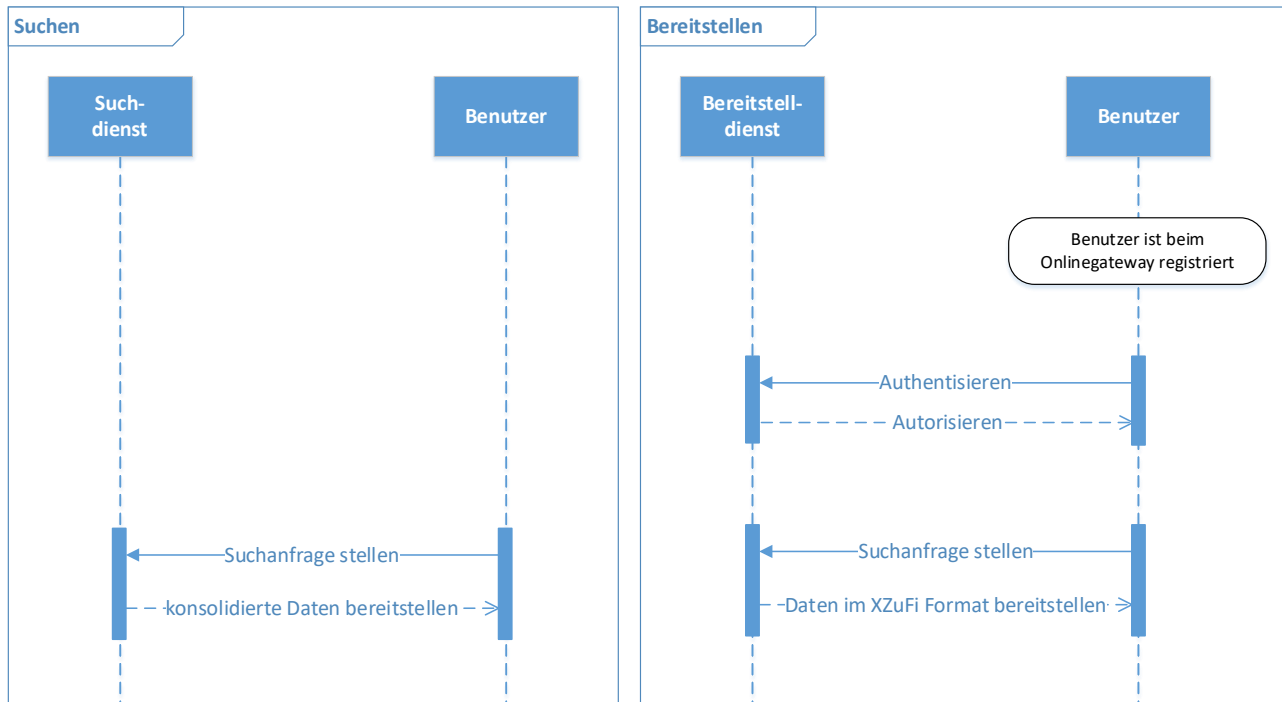


Abbildung 4: Datenabruf über den Suchdienst (links) und den Bereitstelldienst (rechts)

Der Such- bzw. der Bereitstelldienst bieten Schnittstellen an, um auf den internen Katalog von Verwaltungsleistungen des Onlinegateways zuzugreifen.

Der Suchdienst verfügt über eine API-Schnittstelle, um anderen Anwendungen Zugriff auf den Datenbestand zu gewähren. Eine Weboberfläche, die auch als Referenzimplementierung dient, ist für Nutzerinnen und Nutzer gedacht, die den Suchdienst/ Suchclient über ihren Webbrowser aufrufen. Der Ablauf einer Anfrage ist in Abbildung 4 auf der linken Seite dargestellt. Die Suchanfrage selbst erfolgt entweder über die API oder über die Formularfelder der Weboberfläche des Suchclients. Die Dienste des Suchdienstes sind öffentlich ohne Registrierung zugänglich und bieten weitreichende Möglichkeiten die Suchkriterien zu definieren (bspw. nach Ort und Lebenslage).

Der Bereitstelldienst stellt für registrierte Nutzer eine API zur Verfügung. Darüber können ebenfalls Informationen über Verwaltungsleistungen, Organisationseinheiten und zugehörige Onlinedienste bezogen werden. Im Unterschied zum Suchdienst ermöglicht der Bereitstelldienst das Abrufen einer großen Anzahl von Datensätzen bzw. des gesamten Verzeichnisses der Verwaltungsleistungen. Er ermöglicht dadurch einerseits die initiale Befüllung einer selbst gehosteten Datenbank oder andererseits die Synchronisation mit aktualisierten Datensätzen. Hierbei kann die Ergebnisliste der Anfrage auf bestimmte Regionen (über die hierarchisch organisierten amtlichen Regionalschlüssel) eingeschränkt werden. Der Prozess zum Abrufen der Daten ist als Sequenzdiagramm in Abbildung 4 auf der rechten Seite dargestellt.

2.2 Schlüsselwörter

In den Anforderungen werden die in Versalien geschriebenen Modalverben „SOLLTE“ und „MUSS“ in ihren jeweiligen Formen sowie den zugehörigen Verneinungen genutzt, um zu verdeutlichen, wie die jeweiligen Anforderungen zu interpretieren sind. Die hier genutzte Definition basiert auf dem BSI IT-Grundschutz [4] und RFC2119 [5].

MUSS/ DARF NUR:	Dieser Ausdruck bedeutet, dass es sich um eine Anforderung handelt, die unbedingt erfüllt werden muss (uneingeschränkte Anforderung).
DARF NICHT/ DARF KEIN:	Dieser Ausdruck bedeutet, dass etwas in keinem Fall getan werden darf (uneingeschränktes Verbot).
SOLLTE:	Dieser Ausdruck bedeutet, dass eine Anforderung normalerweise erfüllt werden muss, es aber Gründe geben kann, dies doch nicht zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.
SOLLTE NICHT/ SOLLTE KEIN:	Dieser Ausdruck bedeutet, dass etwas normalerweise nicht getan werden sollte, es aber Gründe gibt, dies doch zu tun. Dies muss aber sorgfältig abgewogen und stichhaltig begründet werden.
KANN:	Dieser Ausdruck bedeutet, dass eine bestimmte Umsetzung gewählt werden kann. Diese muss allerdings angezeigt werden.

Die Technische Richtlinie repräsentiert den Stand der Technik und wird fortlaufend aktualisiert.

3 Sicherheitsanforderungen

Betreiber von IT-Systemen für den Portalverbund sind gemäß § 2 Absatz 1 der IT-Sicherheitsverordnung Portalverbund (ITSiV-PV) [6] verpflichtet, Maßnahmen zur Gewährleistung der IT-Sicherheit nach dem Stand der Technik zu treffen. Die vorliegende Technische Richtlinie dokumentiert den Stand der Technik und soll die Verantwortlichen bei der Umsetzung unterstützen.

3.1 Allgemeine Anforderungen

In diesem Abschnitt werden grundlegende Anforderungen an das Onlinegateway formuliert, die überwiegend auf technische oder organisatorische Maßnahmen abzielen.

- A3.1.01** Die BSI-Standards 200-1, 200-2 und 200-3 [7] oder die Vorgaben der ISO/IEC 27001 [8] MÜSSEN in der jeweils geltenden Fassung umgesetzt werden. Als Mindestniveau MUSS die Standardabsicherung für den betreffenden Informationsverbund gewählt werden. Der Informationsverbund des Onlinegateways MUSS nach ISO 27001 auf der Basis von IT-Grundschutz zertifiziert sein. Das IT-Grundschutz-Kompendium [4] MUSS in der aktuellen Version verwendet werden.
- A3.1.02** Der BSI-Standard 200-4 [9] oder die Vorgaben der ISO-Norm 22301:2019 [10] MÜSSEN in der jeweils geltenden Fassung umgesetzt werden. Schnittstellen zu angeschlossenen Diensten SOLLTEN berücksichtigt werden. Es MÜSSEN im Rahmen des Notfallmanagements Maßnahmen getroffen werden, wie mit Sicherheitsvorfällen umzugehen ist.
- A3.1.03** Die verantwortlichen Betreiber MÜSSEN die Verfügbarkeitsanforderungen an das Onlinegateway dokumentieren und die Architektur der beteiligten Systemkomponenten daran ausrichten.
- A3.1.04** Bei der Ermittlung der Verfügbarkeitsanforderung MUSS die potentielle Nutzerbasis berücksichtigt werden. Es SOLLTEN Lasttests durchgeführt werden, um die Skalierbarkeit und Stabilität der Infrastruktur zu gewährleisten.
- A3.1.05** Im Sicherheitskonzept MUSS der Reaktionsprozess bei Bekanntwerden einer Schwachstelle im Onlinegateway auf Basis ihrer Kritikalität klar definiert sein. Der Reaktionsprozess und die Frist zum Weiterbetrieb MÜSSEN allen Beteiligten bekannt sein. Der Weiterbetrieb des Onlinegateways bei bekannter Schwachstelle DARF NICHT länger sein als die im Sicherheitskonzept definierte Übergangsfrist. Es MUSS eine *security.txt* nach RFC 9116 [11] implementiert und regelmäßig aktualisiert werden.
- A3.1.06** Sämtliche, mit öffentlichen Netzen verbundenen Komponenten des Onlinegateways MÜSSEN mittels eines Penetrationstests und eines Webchecks vor Anschluss an den Portalverbund überprüft werden. Penetrationstests und Webchecks MÜSSEN spätestens nach 3 Jahren oder bei größeren Änderungen wiederholt werden.¹

3.2 Architektur und Infrastruktur

In diesem Abschnitt werden Richtlinien zum Anwendungsdesign sowie erweiterte Anforderungen an die Server- und Netzwerkinfrastruktur formuliert.

- A3.2.01** Es MUSS das Prinzip *Security-by-Design* angewendet werden, d.h. Sicherheitsanforderungen an Soft- und Hardware MÜSSEN in der Anwendungsarchitektur und allen Entwicklungs- und Lebenszyklusphasen berücksichtigt werden (vgl. [12]).

¹ siehe auch IT-SiV-PV § 2

- A3.2.02** Der Hersteller/ Entwickler des Onlin gateways SOLLTE eine umfassende Liste aller Abhängigkeiten externer Software, Bibliotheken und Frameworks führen und dabei eine *Software Bill of Materials* gemäß den Anforderungen der BSI TR-03183-2 "Cyber-Resilienz-Anforderungen an Hersteller und Produkte" [13] erstellen und pflegen. Eingebundene externe Software, Bibliotheken oder Frameworks MÜSSEN aus vertrauenswürdigen Quellen stammen; sie MÜSSEN aktuell gehalten werden und mit Sicherheitsupdates versorgt werden. Nicht verwendete Funktionen SOLLTEN deaktiviert werden.
- A3.2.03** Die Webkomponente des Suchdienstes sowie die Anwendungsschnittstellen des Onlin gateways SOLLTEN durch eine *Web Application Firewall* (WAF) geschützt werden. Die Konfiguration der eingesetzten WAF SOLLTE auf den zu schützenden Webservice angepasst werden. Nach jedem Update des Webservices SOLLTE die Konfiguration der WAF geprüft werden. Zusätzlich SOLLTE ein *Intrusion Detection System* (IDS) eingesetzt werden.
- A3.2.04** Der administrative Zugriff auf das System des Onlin gateways MUSS über ein separiertes Netzwerkinterface (Managementnetz) erfolgen, um eine Trennung zum Produktivnetz zu erreichen. Der Austausch von Informationen SOLLTE innerhalb des internen Netzes verschlüsselt stattfinden.
- A3.2.05** Es MÜSSEN *Deny by Default* Netzwerkrichtlinien oder Firewallregeln umgesetzt werden. In Abhängigkeit der Anwendung SOLLTEN weitere Regeln (z. B. Segmentierung) erstellt werden. Netzwerkdienste, die nicht benötigt werden, MÜSSEN deaktiviert werden. Es KANN das Zero-Trust-Prinzip [14] umgesetzt werden.
- A3.2.06** Um die Authentizität und Integrität von DNS sicherzustellen, SOLLTE die DNS-Sicherheitserweiterung DNSSEC konfiguriert werden. Konkrete Informationen sind in der BSI-Veröffentlichung „Umsetzung von DNSSEC“ [15] aufgelistet.
- A3.2.07** Die Produktivumgebung MUSS von weiteren Betriebsumgebungen getrennt betrieben werden. Zusätzlich SOLLTEN weitere Betriebsumgebungen für verschiedene Zwecke voneinander getrennt betrieben werden (z. B. Entwicklungsumgebung, Testumgebung, Stagingumgebung).

3.3 Build-, Release- und Deploymentmanagement

Dieses Kapitel beschreibt Anforderungen an die Bereitstellung und Aktualisierung von Software in den Produktphasen der Entwicklung, der Bereitstellung und während des Betriebs.

- A3.3.01** Es MUSS ein *Build-, Release- und Deploymentmanagement* umgesetzt werden, welches Prozesse zur Erstellung, Prüfung und Verteilung der Builds und Releases sowie zum Deployment enthält. Die Prozesse SOLLTEN dokumentiert, protokolliert und im Sicherheitskonzept berücksichtigt werden.
- A3.3.02** Alle erstellten Softwarepakete und Updates SOLLTEN vor der Auslieferung mindestens fortgeschritten signiert werden. Die Gültigkeit der Signatur MUSS vor der Bereitstellung und Installation jeglicher Software validiert werden. Releases DÜRFEN NUR eingespielt werden, wenn sie erfolgreich validiert worden sind.
- A3.3.03** Versionierungen MÜSSEN verständlich und nachvollziehbar gewählt werden. Release Notes MÜSSEN erstellt werden. Insbesondere SOLLTEN Informationen zu sicherheitskritischen Updates und Supportdauer einer Version enthalten sein.
- A3.3.04** Das Einspielen (Deployment) der Softwarepakete und Updates in eine Produktivumgebung SOLLTE automatisiert und mit konsistenter Konfiguration stattfinden. Es KÖNNEN Tools von kontinuierlicher Integration (*Continuous Integration*) sowie kontinuierlicher Verteilung (*Continuous Deployment*) verwendet werden. Der Prozess des Einspielens SOLLTE manuell ausgelöst werden.

3.4 Authentisierung, Authentifizierung und Autorisierung

Die Anforderungen in diesem Abschnitt richten sich vorrangig an System- und Fachadministratoren sowie an registrierte Konsumenten der Schnittstellen, da der Suchdienst über seine Weboberfläche und die bereitgestellte API öffentlich und allgemein zugänglich ist.

- A3.4.01** Für das Onlinegateway MUSS ein Berechtigungskonzept mit Rechte- und Rollenmanagement erstellt werden, das die technische Einrichtung, die Administration sowie die Schnittstellen für die Schnittstellenkonsumenten beinhaltet. Dabei MUSS definiert werden, wie eine Authentifizierung durchzuführen ist, um unberechtigte Systemzugriffe zu verhindern.
- A3.4.02** Berechtigungen auf Ressourcen und Dienste SOLLTEN bedarfsgerecht einer Rolle zugewiesen werden. Hilfestellungen dafür finden sich im IT-Grundschutz-Kompendium (vgl. ORP.4 Identitäts- und Berechtigungsmanagement [4]). Dabei MUSS das *Principle of Least Privilege* (PoLP) Anwendung finden, d. h. Nutzer SOLLTEN nur über die erforderlichen Rechte verfügen, die sie unbedingt gemäß ihrer ausgeübten Rolle benötigen.
- A3.4.03** Das Berechtigungskonzept SOLLTE eine *Deny-by-Default* Strategie verfolgen, d. h. Zugriffe auf Ressourcen und Dienste SOLLTEN unterbunden werden, es sei denn sie werden ausdrücklich zugelassen.
- A3.4.04** System- und Fachadministratoren MÜSSEN sich bei Zugriff über öffentliche Netze mittels Multi-Faktor-Authentisierung (MFA) authentisieren.
- A3.4.05** Redaktionssysteme MÜSSEN für die Kommunikation mit dem Onlinegateway identifiziert und berechtigt werden. Für die Autorisierung MUSS ein eindeutiges Berechtigungskonzept vorliegen, in dem definiert ist, welche Dienste und Ressourcen das Redaktionssystem nutzen kann.
- A3.4.06** Für die initiale Anbindung eines Redaktionssystems an das Onlinegateway MUSS eine geeignete Authentisierung und anschließende Authentifizierung stattfinden.
- A3.4.07** Beim Datenupload zum Sammlerdienst des Onlinegateways (Push-Verfahren) MUSS sich das Redaktionssystem authentisieren.
- A3.4.08** Beim Datendownload über den Bereitstellendienst des Onlinegateways MUSS sich der Konsument der Schnittstelle authentisieren.

3.5 Session-Management

Die im Internet eingesetzten Übertragungsprotokolle sind überwiegend zustandslos. Daher bedarf es eines Session-Managements um Sitzungen zwischen den Kommunikationspartnern zu etablieren. An dieser Stelle sei explizit auf den Baustein CON.10 im IT-Grundschutz-Kompendium [4] hingewiesen. Weitere ergänzende Anforderungen sind im Folgenden aufgeführt.

- A3.5.01** Um die sichere Verwaltung von autorisierten Benutzern des Onlinegateway zu gewährleisten, MUSS ein Session Management implementiert werden.
- A3.5.02** Zustandsabhängige Sitzungskennungen auf dem Server MÜSSEN nach dem Abmelden als ungültig markiert werden um eine erneute Authentisierung zu erzwingen.
- A3.5.03** In Sessions, bei denen eine Authentifizierung erforderlich ist, MUSS das Onlinegateway nach einer festgelegten Zeitspanne ohne Benutzeraktivität die Session als ungültig markieren und eine erneute Authentisierung verlangen.
- A3.5.04** Angemeldete Benutzer MÜSSEN die Möglichkeit haben sich explizit abzumelden. Die mit der Anmeldung erteilten Nutzerrechte MÜSSEN mit der Abmeldung zurückgezogen werden, bis eine erneute Authentisierung erfolgt.
- A3.5.05** HTTP-Response-Header MÜSSEN restriktiv konfiguriert werden um zu verhindern, dass unnötige Informationen preisgegeben werden.

- A3.5.06** Im Browser persistierte Daten, wie *Cookies*, *Local Storage* oder *Session Storage*, SOLLTEN so konfiguriert werden, dass sie für weitere Hosts (Subdomains) derselben Hauptdomain unlesbar sind.
- A3.5.07** Es MÜSSEN Maßnahmen nach Stand der Technik gegen Session Angriffe, u. a. *Session Fixation*, *Session Hijacking*, *Cross-Site Request Forgery* (CSRF) und *Replay Attacks*, implementiert werden.
- A3.5.08** Beim Einsatz von *Access Token*, bspw. JSON-Web-Token (JWT), MÜSSEN diese über eine verschlüsselte und integritätsgesicherte Verbindung ausgetauscht werden. Sie SOLLTEN keine vertraulichen Informationen enthalten. *Self-contained token* DÜRFEN NUR eine kurzfristige Gültigkeit (max. 5 min) aufweisen und sie MÜSSEN signiert sein. Die Signatur MUSS vor dem Zugriff auf den Dienst oder die Ressource validiert werden. Wenn *Reference Token* eingesetzt werden, MÜSSEN sie bei jeder Abfrage beim ausstellenden Autorisierungsserver validiert werden.

3.6 Schnittstellen und Datenübertragung

Die Anwendungsschnittstellen beim Onlinegateway dienen hauptsächlich der *Machine-to-Machine* (M2M) Kommunikation. Dieser Abschnitt richtet sich besonders an Schnittstellen, die gemäß der REST-API Architektur gestaltet sind. Die Anforderungen gelten allerdings sinngemäß auch für Schnittstellen, die anderen Programmierparadigmen folgen (SOAP, RPC, ...).

- A3.6.01** Es MÜSSEN sichere Protokolle zum Austausch von Nutzdaten zwischen den externen Akteuren und dem Onlinegateway verwendet werden um die Vertraulichkeit und Integrität sicherzustellen. Insbesondere MUSS die Webanwendung des Suchclients *Transport Layer Security* (TLS) in einer sicheren Version unterstützen. Unsichere Versionen von TLS SOLLTEN deaktiviert werden. Der Webserver SOLLTE Umleitungen vom *Hyper Text Transfer Protocol* auf *Hyper Text Transfer Protocol Secure* (HTTPS) einrichten.
- A3.6.02** Die öffentlich erreichbaren Anwendungsschnittstellen und Dienste des Onlinegateways MÜSSEN durch geeignete Maßnahmen vor *Denial-of-Service* (DoS) und *Distributed-Denial-of-Service* (DDoS) Angriffen geschützt werden.
- A3.6.03** Der Datenaustausch zwischen registrierten Konsumenten der Schnittstellen und dem Onlinegateway MUSS den Vorgaben nach BSI TR-03116-4 „Kryptographische Vorgaben für Projekte der Bundesregierung Teil 4 – Kommunikationsverfahren in Anwendungen“ [16] in der aktuellen Fassung erfüllen. Die anzuwendenden Algorithmen MÜSSEN in Abhängigkeit der genutzten Protokolle gewählt werden. Die BSI TR-03116-4 enthält entsprechende Vorgaben für Transport- (TLS) und Inhaltsverschlüsselung in den jeweiligen Kapiteln.
- A3.6.04** Alle Anwendungsschnittstellen MÜSSEN vollständig dokumentiert sein. Nicht verwendete Schnittstellen MÜSSEN abgeschaltet werden.
- A3.6.05** Es DÜRFEN KEINE vertraulichen Informationen in der URL ersichtlich sein oder übertragen werden.
- A3.6.06** Der Austausch der Inhaltsdaten über die Anwendungsschnittstelle des Onlinegateways (Push, Pull-Verfahren des Sammlerdienstes und die API des Bereitstellendienstes) MUSS über das XZuFi Datenformat erfolgen [3].
- A3.6.07** Der *XML-Parser* MUSS die Spezifikationen des W3C befolgen (vgl. [17]) und DARF KEINE weiteren Maßnahmen ergreifen um nicht wohlgeformte Dokumente zu interpretieren. Im Falle, dass während der Verarbeitung des Dokumentes ein Fehler auftritt, MUSS die Verarbeitung abgebrochen werden. Es SOLLTE eine Fehlermeldung an das betreffende Redaktionssystem erfolgen.
- A3.6.08** Leistungsbeschreibungen für Verwaltungsdienste, die über das Push- und Pull-Verfahren des Sammlerdienstes bezogen werden, MÜSSEN auf Schemakonformität und Schadsoftware hin überprüft werden. Bei Nichtbestehen einer der Prüfungen MUSS der Datensatz verworfen werden und das verantwortliche Redaktionssystem SOLLTE über den Umstand benachrichtigt werden.

- A3.6.09** Es MÜSSEN Maßnahmen getroffen werden um die Ausführung von Softwarecode bspw. aus Formularfeldern (*Code Injection*) oder *XML External Entity* Angriffen (XXE) zu verhindern.
- A3.6.10** Managementendpunkte einer REST API SOLLTEN nicht über öffentliche Netze zugänglich sein. Bei Verwendung von Managementendpunkten über öffentliche Netze MÜSSEN diese über eine Multi-Faktor Authentifizierung abgesichert werden. Ihr Zugriff SOLLTE über separate Zugänge (z. B. eigene IP-Adressen oder dedizierte TCP-Ports) erfolgen und er SOLLTE durch restriktive Firewallereinstellungen abgesichert werden.
- A3.6.11** HTTP Statuscodes SOLLTEN in der REST API semantisch korrekt verwendet werden. Sie SOLLTEN analysiert werden und dazu verwendet werden um Angriffe auf das Onlinegateway zu identifizieren.

3.7 Protokollierung und Detektion

Die in diesem Abschnitt formulierten Anforderungen sind als Ergänzungen zu den Grundsatzbausteinen OPS.1.1.5 Protokollierung und DER.1 Detektion aufgeführt [4].

- A3.7.01** Es MÜSSEN alle betriebs- und sicherheitsrelevanten Ereignisse sowie fehlgeschlagene Datenübertragungen zwischen Onlinegateway und Redaktionssystemen protokolliert werden.
- A3.7.02** Die gesammelten Protokollierungsdaten MÜSSEN automatisch in einem separaten Netzsegment zentral gespeichert und für die Auswertung bereitgestellt werden, um im Bedarfsfall eine erfolgreiche und nachvollziehbare Vorfallobarbeitung durchführen zu können.
- A3.7.03** Es MÜSSEN die Vorgaben des Mindeststandards des BSI nach § 8 Abs. 1 Satz 1 BSIG zur Protokollierung und Detektion von Cyber-Angriffen [18] eingehalten werden.
- A3.7.04** Es SOLLTE ein *Security Information and Event Management* (SIEM) vorhanden sein, welches eine Häufung von atypischem Verhalten auf Basis der Logfiles detektiert und bei Überschreiten eines Schwellwerts eskaliert.
- A3.7.05** Es MUSS sichergestellt sein, dass die Administratoren des Onlinegateways keine Berechtigung haben, die aufgezeichneten Protokollierungsdaten zu erstellen, zu verändern oder zu löschen.
- A3.7.06** Jede administrative Handlung, sowohl technischer als auch fachlicher Art, MUSS eindeutig auf eine Person zurückführbar sein und protokolliert werden. Dies kann bspw. durch eine entsprechende Benutzerkennung innerhalb des Rollenmanagements erreicht werden.

3.8 Konfiguration

Die Konfiguration einer Webanwendung umfasst sowohl alle Einstellungen der Anwendungskomponenten als auch die Konfiguration der Server und beteiligten aktiven Netzkomponenten, wie beispielsweise Firewalls, Gateways und Router.

- A3.8.01** Alle beteiligten Server und Anwendungskomponenten des Onlinegateways SOLLTEN einem strukturierten Härtings- und Minimalisierungsprozess unterworfen sein.
- A3.8.02** Alle Konfigurationen MÜSSEN durch regelmäßige Backups auf Anwendungsebene und auf IT-Systemebene gesichert werden. Vor Administrationstätigkeiten mit potenziell weitreichenden Folgen SOLLTE ein zusätzliches Backup gemacht werden. Konfigurationsbackups SOLLTEN unabhängig vom Hostsystem und redundant gespeichert werden. Eine Zuordnung nach Herkunft und Erstellungszeitpunkt MUSS sichergestellt sein. Es MUSS gewährleistet sein, dass die Backups im Fehlerfall wieder eingespielt werden können.
- A3.8.03** Um zu vermeiden, dass Administrierende sich durch eine fehlerhafte Konfiguration dauerhaft aussperren, MUSS ein Notfall-Verfahren eingerichtet und dokumentiert werden.

- A3.8.04** Es SOLLTE eine Integritätssicherung der Konfiguration stattfinden, um Beschädigungen und Manipulationen der Konfigurationsdateien feststellen zu können. Die Integritätssicherung SOLLTE regelmäßig durch die Administratoren überprüft werden.
- A3.8.05** In der Produktivumgebung SOLLTE kein Debug-Modus aktiv sein.

3.9 Fehlerbehandlung

Die sichere Fehlerbehandlung hat zum Ziel, dass weder kritische Informationen des Onlinegateways veröffentlicht werden, noch dass es zu einem inkonsistenten Betriebszustand kommt, der durch Angreifer ausgenutzt werden kann.

- A3.9.01** Treten während der Laufzeit des Onlinegateways Fehler auf, MÜSSEN diese so behandelt werden, dass das Onlinegateway weiter in einem konsistenten Zustand bleibt. Die Fehlerursachen SOLLTEN behoben werden (Programmierfehler, Eingabevalidierung, etc.) Die Fehlerursachen MÜSSEN identifiziert und, abhängig von ihrer Kritikalität, entweder unverzüglich (Hotfix) oder im Rahmen eines regulären Updates behoben werden.
- A3.9.02** Falls eine veranlasste Aktion einen Fehler verursacht, MUSS das Onlinegateway diese Aktion abbrechen. Das Onlinegateway MUSS im Fehlerfall den Zugriff auf eine angeforderte Ressource oder Funktion verweigern.
- A3.9.03** Zuvor reservierte Ressourcen SOLLTEN im Rahmen der Fehlerbehandlung wieder freigegeben werden. Der Fehler SOLLTE möglichst innerhalb der Programmierlogik des Onlinegateways selbst abgefangen und behandelt werden.

Literaturverzeichnis

- [1] Bundesamt für Sicherheit in der Informationstechnik, „Technische Richtlinie TR-03172,“ 2024. [Online]. Available: https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03172/BSI-TR-03172_Rahmendokument.pdf?__blob=publicationFile&v=8.
- [2] Bundesamt für Sicherheit in der Informationstechnik, „BSI TR-03172 Portalverbund,“ 2024. [Online]. Available: https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/Technische-Richtlinien/TR-nach-Thema-sortiert/tr03172/TR-03172_node.html.
- [3] XRepository 3.0, „XZuFi - XÖV-Standard für Zuständigkeitsfinder,“ [Online]. Available: <https://www.xrepository.de/details/urn:xoev-de:fim:standard:xzufi>. [Zugriff am 23 05 2024].
- [4] BSI, „IT-Grundschutz-Kompendium,“ 1 2 2023. [Online]. Available: https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/IT-Grundschutz-Kompendium/it-grundschutz-kompendium_node.html. [Zugriff am 30 4 2024].
- [5] RFC-Editor, „RFC 2119 - Key words for use in RFCs to Indicate Requirement Levels,“ 1997. [Online]. Available: <https://www.rfc-editor.org/info/rfc2119>. [Zugriff am 22 04 2024].
- [6] Bundesrepublik Deutschland, *IT-Sicherheitsverordnung Portalverbund - ITSiV-PV vom 6. Januar 2022*, Bundesgesetzblatt Jahrgang 2022 Teil I Nr. 2, ausgegeben am 19.01.2022, Seite 18, 2022.
- [7] Bundesamt für Sicherheit in der Informationstechnik, „BSI-Standards,“ [Online]. Available: <https://www.bsi.bund.de/dok/6603458>. [Zugriff am 26 10 20023].
- [8] ISO/IEC 27001:2013, „Information technology - Security techniques - Information Security management systems - Requirements,“ *International Organization for Standardization (Hrsg.)*, 2013.
- [9] Bundesamt für Sicherheit in der Informationstechnik, „BSI-Standard 200-4 Business Continuity Management,“ 2023. [Online]. Available: https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/BSI-Standards/BSI-Standard-200-4-Business-Continuity-Management/bsi-standard-200-4_Business_Continuity_Management_node.html. [Zugriff am 30 05 2024].
- [10] ISO 22301:2019, International Organization for Standardization (Hrsg.), „Security and resilience - Business continuity management systems - Requirements,“ *ISO/TC 292*, 2019.
- [11] E. Foudil, „datatracker.ietf.org,“ Network Working Group, 04 2022. [Online]. Available: <https://datatracker.ietf.org/doc/html/rfc9116>. [Zugriff am 01 12 2024].
- [12] Cybersecurity & Infrastructure Security Agency, „Secure-by-Design,“ 25 10 2023. [Online]. Available: <https://www.cisa.gov/resources-tools/resources/secure-by-design>. [Zugriff am 24 07 2024].
- [13] Bundesamt für Sicherheit in der Informationstechnik, „BSI TR-03183 Cyber-Resilienz-Anforderung,“ BSI, 2024. [Online]. Available: <https://www.bsi.bund.de/dok/TR-03183>. [Zugriff am 06 12 2024].
- [14] Bundesamt für Sicherheit in der Informationstechnik, „Positionspapier Zero Trust 2023,“ 04 07 2023. [Online]. Available: https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeLeitlinien/Zero-Trust/Zero-Trust_04072023.htm. [Zugriff am 10 03 2025].

- [15] Bundesamt für Sicherheit in der Informationstechnik, BSI, „Umsetzung von DNSSEC,“ 29 06 2015. [Online]. Available: https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Cyber-Sicherheit/Themen/Umsetzung_von_DNSSEC.pdf?__blob=publicationFile&v=1. [Zugriff am 30 05 2024].
- [16] Bundesamt für Sicherheit in der Informationssicherheit, „Technische Richtlinie BSI TR-03116-4,“ BSI, 07 03 2023. [Online]. Available: https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/TechnischeRichtlinien/TR03116/BSI-TR-03116-4.pdf?__blob=publicationFile&v=5. [Zugriff am 01 12 2024].
- [17] W3C, „Extensible Markup Language (XML),“ [Online]. Available: <https://www.w3.org/XML/>. [Zugriff am 10 03 2025].
- [18] Bundesamt für Sicherheit in der Informationstechnik, „Mindeststandard des BSI nach § 8 Abs. 1 Satz 1 BSIG zur Protokollierung und Detektion von Cyberangriffen Version 2.1,“ BSI, 11 11 2024. [Online]. Available: https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Mindeststandards/MST_BSI_PD_Version_2_1.html. [Zugriff am 01 12 2024].